SOC Investigation — Phishing Email & Fake Webmail Login Page

Source: malware-traffic-analysis.net

Tools Used: Wireshark, Sublime Text, VirusTotal, AbuseIPDB

Category: Phishing / Credential

Analyst: Mubeen

Overview

This investigation analyzes a phishing email and the associated network traffic generated when a victim visits a fake webmail login page. The exercise provided a PCAP file captured using HTTP (rather than HTTPS) for the phishing URL, allowing full visibility into the credential submission via TCP stream analysis. The goal was to:

- Analyze email headers for spoofing and authentication failures
- Identify the phishing infrastructure
- Trace the credential harvesting flow in Wireshark
- Extract IOCs and map techniques to MITRE ATT&CK

Phase 1 — Email Header Analysis

The phishing email presented several immediate red flags upon header inspection.

Field	Value
From	`SupportDesk <khz.port@scp.gov.iq>`
Relay Server	`s940027.srvape.com`
Sending IP	`188.127.247.252`
Subject	`Account Validation!! For admin@malware-traffic-analysis.net Only!!`
SPF	FAIL — sending IP not authorized for domain
DKIM	None
DMARC	Fail (implicit — SPF fail + no DKIM)

Key Observations

Domain mismatch: The claimed sender uses `scp.gov.iq` (an Iraqi government domain), but the email was relayed through `srvape.com` — an entirely unrelated hosting provider. This is a classic header mismatch indicating spoofing or compromised infrastructure.

Authentication triple failure: SPF hard fail, no DKIM signature, and implicit DMARC failure. A properly configured mail gateway should have quarantined or rejected this email at the perimeter.

Targeted lure: The subject line embeds the victim's email address directly — `"Account Validation!! For admin@malware-traffic-analysis.net Only!!"` — to create a false sense of legitimacy and urgency.

Phase 1b — Raw .eml Source Analysis

Opening the raw `.eml` file in a text editor (Sublime Text) revealed additional detail not visible in a standard email client.

Quoted-Printable Encoding

The email body uses Quoted-Printable (QP) encoding, a standard MIME format for transmitting HTML email. This means `=3D` throughout the source decodes to `=` . For example:

```
href=3D"https://email.procedure.best/management.aspx?good=3Dadmin@malware-traffic-ana
```

Decodes to: `href="https://email.procedure.best/management.aspx?good=admin@malware-traffic-analysi`

This is worth noting because QP encoding can sometimes be used to obscure URLs from basic email scanners that don't decode before inspection.

Page Title Spoofing

The HTML `<title>` tag reads `Email Validation` and the visible header renders as "malwaretraffic-analysis.net Validation" — the attacker used the target's own domain name in the page content to make it appear internal and legitimate.

Explicit Password Request

Line 56 of the source reads:

> *"Kindly input your email password for validation 8/28/2024 3:06:26 a.m."*

This is a particularly aggressive social engineering element — the attacker explicitly asks for the password and includes a fabricated timestamp to add urgency and a false audit trail.

Phase 2 — Phishing URL & Infrastructure Analysis

The email contained a single malicious link:

```
hxxps://email.procedure[.]best/management.aspx?good=admin@malware-traffic-analysis[.]
```

Infrastructure Breakdown

Component	Detail
Phishing Domain	`email.procedure[.]best`
URL Parameter	`?good=admin@malware-traffic-analysis[.]net` — pre-populates login form
Hosting	Behind Cloudflare (`172.67.0.0/16` or `104.21.0.0/16`)
Protocol Used in Exercise	HTTP (intentional — enabled full PCAP visibility)

Why Cloudflare? Threat actors frequently place phishing pages behind Cloudflare to mask the true origin server IP, complicate attribution, and make takedowns harder. The dynamic IP range means blocking a single IP is ineffective.

The `?good=` parameter is a credential harvesting technique — the victim's email is passed in the URL so the fake login page auto-populates the username field, reducing friction and increasing the likelihood of credential submission.

Phase 3 — Wireshark Traffic Analysis

Recommended Filters

```
# Isolate traffic to the phishing domain
http.host contains "procedure"

# Find the credential POST request http.request.method
== "POST"

# View all HTTP requests http.request
```

```
# TLS SNI if HTTPS was used
tls.handshake.extensions_server_name contains "procedure"
```

Observed HTTP Request Sequence (from PCAP)

Victim IP: `10.0.29.128`

Phishing Server IP: `172.67.202.104` (Cloudflare — resolves to `email.procedure[.]best`)

Timestamp (UTC)	Method	Request	Notes
2024-08-29 21:03:16	GET	`/management.aspx?good=admin@malware-trafficanalysis.net`	Victim clicks link — fake login page loads
2024-08-29 21:03:17	GET	`/translate_a/element.js?cb=on`	JavaScript resource load
2024-08-29 21:03:17	GET	`/favicon.ico`	Pre-submission connectivity check
2024-08-29 21:03:19	GET	`/management.aspx?good=admin@malware-trafficanalysis.net`	Page reload
2024-08-29 21:03:19	POST	`/management.aspx?good=admin@malware-trafficanalysis.net`	Credentials submitted — cleartext over HTTP
2024-08-29 21:03:19	GET	`/gen204?...`	Beacon/tracking ping post-submission
2024-08-29 21:03:36	POST	`/management.aspx?good=admin@malware-trafficanalysis.net`	Second credential submission
2024-08-29 21:03:37	GET	`/management.aspx`	Follow-up page load
2024-08-29 21:03:37	GET	`/favicon.ico`	Second connectivity check

2024-08-29 21:03:37	GET	`/gen204?...`	Second beacon ping

Key Observations from PCAP

Confirmed victim IP: `10.0.29.128` is the machine that clicked the link and submitted credentials. In a real incident this would be your priority containment target.

Confirmed phishing server IP: `172.67.202.104` — a Cloudflare IP, consistent with our infrastructure analysis. Domain-level blocking is required; IP blocking alone is ineffective.

Double credential POST: The victim submitted credentials twice (21:03:19 and 21:03:36), likely after the phishing page returned an error or re-prompted. This is a deliberate phishing kit technique to capture and confirm the password.

`/gen204` signal requests: These are Google Analytics-style tracking pings used by the phishing kit to log victim interaction events. This indicates the attacker was actively monitoring submissions.

`/favicon.ico` as a connectivity check: The favicon request appearing immediately before the POST is consistent with a phishing kit pre-submission check — confirming the server is reachable before the credential data is sent.

TCP Stream — Credential Exfiltration

Because HTTP was used instead of HTTPS, following the TCP stream of the POST request at 21:03:19 reveals the submitted credentials in plaintext. This is the most critical artifact of the investigation — direct evidence of credential theft.

> Analyst Note: In a real-world scenario with HTTPS, the POST body would be encrypted. However, the TLS SNI field in the Client Hello would still confirm the domain, and proxy/DLP logs may capture credential submission events.

HTTP Response Analysis (filter: **`http.response`**)

Applying the `http.response` display filter revealed the full server-side response sequence and confirmed two additional infrastructure findings.

Frame	Time	Source	Destination	Length	Response	Notes
286	21:03:17	`172.67.202.104`	`10.0.29.128`	728	200 OK (text/html)	Phishing page served to victim

540	21:03:19	`172.67.202.104`	`10.0.29.128`	78	301 Moved Permanently	Postsubmission redirect — victim sent away after credentials captured
610	21:03:19	`142.250.115.113`	`10.0.29.128`	1359	204 No Content	Google Analytics beacon response — submission logged
788	21:03:37	`172.67.202.104`	`10.0.29.128`	1084	200 OK (text/html)	Second page load response
896	21:03:37	`142.250.115.113`	`10.0.29.128`	518	301 Moved Permanently	Google redirect
904	21:03:37	`142.250.115.113`	`10.0.29.128`	1360	204 No Content	Second beacon response

Key finding — 301 redirect post-submission: Immediately after the credential POST, the phishing server issued a `301 Moved Permanently` redirect. This is a deliberate phishing kit technique — the victim is silently redirected to a legitimate page (likely the real webmail login) so they assume they simply mistyped their password and re-enter it. This explains the second POST at 21:03:36.

Key finding — Google Analytics tracking (**`142.250.115.113`**): The `/gen204` signal requests resolved to a Google-owned IP, confirming the phishing kit is using Google Analytics to track victim submissions in real time. This is a known evasion technique — GA traffic blends with legitimate web traffic and is rarely blocked at the perimeter. The `204 No Content` response is the expected GA ping acknowledgement.

> Analyst Note: The use of Google Analytics by the phishing kit means the attacker received a real-time notification when credentials were submitted — this is not passive harvesting but active, monitored credential theft.

Indicators of Compromise (IOCs)

Type	Value	Notes

Sender Email	khz.port@scp[.]gov[.]iq	Spoofed / compromised gov domain
Sending IP	188.127.247.252	Relay: s940027.srvape.com
Victim Email	admin@malware-traffic-analysis[.]net	Extracted from raw .eml — embedded in URL parameter
Victim IP	10.0.29.128	Internal machine — confirmed via PCAP
Phishing Domain	email.procedure[.]best	Fake webmail login page
Phishing Server IP	172.67.202.104	Cloudflare IP resolving to phishing domain
Phishing URL	hxxps://email.procedure[.]best/management.aspx?good=admin@malware-traffic-analysis[.]net	Credential harvester
Hosting Range	172.67.0.0/16 ,104.21.0.0/16	Cloudflare (dynamic) — block at domain level
URI Parameter	?good=admin@malware-traffic-analysis[.]net	Pre-populates login form via QuotedPrintable encoded value (=3D)
Tracking IP	142.250.115.113	Google Analytics — phishing kit tracking victim submissions in real time

IOCs are defanged. Replace [.] with . before use in threat intel platforms.

MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Phishing: Spearphishing Link	T1566.002

Credential Access	Steal Web Session Cookie / Credentials via Web Form	T1056
Defense Evasion	Use of Legitimate Services (Cloudflare)	T1027
Defense Evasion	Use of Legitimate Services (Google Analytics for C2 tracking)	T1102
Reconnaissance	Victim email embedded in URL	T1598

Attack Chain

```
Phishing Email Received
        |
Victim clicks link - hxxps://email.procedure[.]best/management.aspx?good=admin@malwar
        |
DNS resolves to Cloudflare IP (origin server masked)
        |
Fake webmail login page loads (victim's email pre-populated via ?good= parameter)
        |
Victim enters password - HTTP POST - credentials sent in cleartext
        |
        |── /gen204 beacon - Google Analytics (142.250.115.113) - attacker notified
        |
301 Moved Permanently - victim redirected to legitimate page (conceals the theft)
        |
Victim re-enters password (second POST) - credentials confirmed
        |
Attacker harvests credentials - account takeover
```

Detection Opportunities

Layer	Detection
Email Gateway	SPF/DKIM/DMARC enforcement — this email fails all three
DNS	Alert on newly registered or low-reputation domains
Proxy / Web Filter	Block access to phishing domains; alert on `?good=` style credential pre-fill patterns
Endpoint	Browser security warnings for suspicious sites
Network	DLP alerts on credential POST requests over HTTP

Lessons Learned

1. Email authentication is a first line of defense — SPF, DKIM, and DMARC together form a strong perimeter control. This email failed all three, and a properly configured gateway should have stopped it before delivery.

2. Cloudflare as evasion — Blocking a phishing page hosted behind Cloudflare requires domain-level blocks, not IP blocks. This is an important operational nuance when writing firewall rules.

3. HTTP over HTTPS as an analyst advantage — The attacker's use of HTTP (whether intentional or misconfigured) exposed the full credential POST in the PCAP. In real investigations, TLS inspection capabilities at the proxy layer can replicate this visibility.

4. The `?good=` URL pattern — This is a well-documented credential harvesting technique worth adding to detection rules. Watching for email addresses passed as URL parameters to external, low-reputation domains is a useful hunt query.

5. Google Analytics as attacker infrastructure — The phishing kit abused Google Analytics (`/gen204` beacons) to receive real-time submission notifications. This traffic blends with normal GA traffic and is rarely blocked. Detection requires behavioral analysis of beacon timing relative to form POST events, not just domain blocking.

6. The 301 redirect as deception — The immediate post-submission redirect to a legitimate page is why victims often don't realise they've been phished. It resets their suspicion and prompts a second credential entry, giving the attacker a confirmed password. This pattern — POST → 301 → legitimate site — is a reliable behavioral indicator of phishing kit activity in PCAP analysis.

References

- malware-traffic-analysis.net — 2024-08-29
- MITRE ATT&CK — T1566.002
- MITRE ATT&CK — T1027